A PRACTICAL GUIDE FROM GROWTH PARTNER PROS

AI Trust Boundary Framework

Microsoft 365 Copilot Edition

Where do we trust Copilot, where do we constrain it, and where does human accountability begin?

The same six questions as the original framework, with the Microsoft 365 setting, report or decision that answers each one.

1	2	3	4	5	6
Owner	Data	Environment	Access	Action	Oversight

Caroline Hinton
Founder, Growth Partner Pros
caroline.hinton@growthpartnerpros.com

WHAT CHANGES WITH COPILOT

Copilot uses the access you already gave people

Most AI tools only know what you paste into them. Microsoft 365 Copilot is different. It works inside your email, Teams chats, meetings, OneDrive and SharePoint, and it can draw on anything the person using it is allowed to open.

The one sentence to remember

Copilot doesn't create new access. It finds and uses the access people already have, including access nobody meant to give them. Microsoft's own SharePoint guidance says Copilot can surface broadly shared files a user didn't know they could see.

The six questions, and where each one lives in Microsoft 365

1	**Owner** Who owns the outcome?	A named business owner, plus the Agents page in the Microsoft 365 admin center
2	**Data** What does Copilot actually need to know?	Sensitivity labels in Microsoft Purview
3	**Environment** Where is it processed, and who else touches it?	Work account sign-in, enterprise data protection, web search and AI provider settings
4	**Access** What can Copilot reach?	SharePoint and Teams permissions, SharePoint Advanced Management
5	**Action** What can Copilot change?	Which Copilot you use: Chat, Agent Builder, Copilot Studio or Cowork
6	**Oversight** Where must a human decide, and how do we check what comes out?	Human approval points, plus Purview audit and retention

Why the owner still comes first

Microsoft gives you the switches. Someone with a name and a title still has to decide how to set them.

© 2026 Growth Partner Pros. All Rights Reserved.

WHY IT FEELS FAMILIAR

You already run these controls for money

Each question has a twin in finance, and Microsoft 365 has a setting that does the same job for Copilot.

The AI question	The finance control it mirrors	The Microsoft 365 control
1 Owner	**Budget owner.** One named person answers for the line item.	A named owner for each Copilot use and each agent. Admins can see, block and unblock agents from the admin center.
2 Data	**Need to know.** Payroll files don't go to everyone.	Sensitivity labels mark files as Confidential or Highly Confidential, and Copilot respects them.
3 Environment	**Approved vendors.** You vet a bank before you deposit with it.	Work accounts only, enterprise data protection, and admin settings for web search and other AI model providers.
4 Access	**System access.** Segregation of duties: who can touch what.	SharePoint, OneDrive and Teams permissions, plus tools that find and hide overshared sites.
5 Action	**Approval limits.** A manager can sign up to a set amount.	Choosing the Copilot that can only draft over the one that can send, book or update.
6 Oversight	**The approval matrix,** plus review and reconciliation after the fact.	Human sign-off on consequential decisions, with Copilot activity in Purview audit, retention and eDiscovery.

The short version

These are internal controls for Copilot. Same logic, new kind of worker, and most of the switches already exist in your tenant.

© 2026 Growth Partner Pros. All Rights Reserved.

QUESTION 1 OF 6

Owner: who owns the outcome?

Every Copilot use case and every agent in production has a named business owner. One person, with a title, whose name is on the result.

NOT THIS

"IT turned on Copilot, so IT owns it."

THIS

"The VP of Human Resources owns the 360 summary agent and decides who can use it."

Why this matters more with Copilot

In Microsoft 365, anyone with a Copilot license can build an agent with Agent Builder and share it with colleagues. That's useful, and it means agents can multiply quietly. Each one needs an owner who answers for what it does.

Three things give ownership teeth, the Microsoft way

What it needs	Where it lives in Microsoft 365
A log	Copilot activity is recorded in the Microsoft Purview audit log. How long it's kept depends on your license, so check before you rely on it.
An off switch	Admins can block or unblock an agent for the whole organization from the Agents page in the Microsoft 365 admin center. A person's access can also be removed by unassigning their Copilot license.
A review date	No setting does this for you. Put it on the owner's calendar, and review the agent inventory at the same time.

Worth asking IT

Who holds the AI Administrator role in your tenant? Several of the settings in this guide need that role, and that person should know who the business owners are.

© 2026 Growth Partner Pros. All Rights Reserved.

QUESTION 2 OF 6

Data: what does Copilot need to know?

Copilot can draw on email, chats, meetings and files. For any one task it needs far less. Give each use case the minimum, and label the rest so Copilot treats it with care.

Four classes, mapped to sensitivity labels

Public
Website copy, press releases. Label: Public.

Internal
Process docs, meeting notes, FAQs. Label: General.

Confidential
Contracts, financials, employee records. Label: Confidential.

Restricted
SSNs, bank details, health information, privileged legal. Label: Highly Confidential, with encryption.

Label names vary by organization. Match these four classes to the labels your tenant already uses.

What labels do for Copilot

- **Copilot respects encryption.** If a label encrypts a file and the person doesn't have the right to copy content from it (Microsoft calls this the EXTRACT right), Copilot can't show them its text. It can only point to the file.
- **Labels travel with answers.** Copilot shows the labels of the files it used, and new content created from a labeled file can pick up that label.
- **Labels need a person to set them up.** Publishing labels and deciding which are encrypted is a Purview task. If nobody has done it, Copilot has nothing to respect.

Four ways to handle the data, safest first

1
No sensitive data required

2
Redacted or anonymized data

3
Synthetic or example data, like a made-up 360 for a demo

4
Real confidential data, labeled, in a site with the right permissions

Example: summarizing 360 feedback
Copilot needs one person's ratings and comments from the Forms export. It doesn't need other employees' reviews, pay data, medical leave records or the rest of the HR site.

© 2026 Growth Partner Pros. All Rights Reserved.

QUESTION 3 OF 6

Environment: where is it processed, and who else touches it?

"We use Copilot" doesn't tell you enough. These are different environments, with different controls:

Consumer Copilot
Signed in with a personal Microsoft account. Not for work data.

Copilot Chat
Work account, no Copilot license. Uses the web and files you upload.

Microsoft 365 Copilot
Licensed. Also draws on your email, chats and files.

Agents
Built in Agent Builder or Copilot Studio, with their own knowledge and tools.

Five checks, answered for Copilot

Check	What to confirm in Microsoft 365
1 Account	People sign in with their work account. That's what turns on enterprise data protection, which covers both Copilot Chat and Microsoft 365 Copilot.
2 Training	Under enterprise data protection, Microsoft says prompts, responses and the data Copilot reads aren't used to train its foundation models.
3 Retention	Purview retention policies can cover Copilot prompts and responses, but they aren't retroactive, so set them before rollout. Files uploaded to Copilot Chat are saved in the person's OneDrive. Copilot's memory feature isn't covered by standard holds.
4 Contract	Copilot runs under Microsoft's Product Terms and Data Protection Addendum. I flag questions about them and route them to legal; I don't interpret contracts.
5 Vendor chain	**Web search:** Copilot can send search queries to Bing. Admins can turn this off with a policy. **Other AI providers:** some Copilot features can use Anthropic's models, with Anthropic as a Microsoft subprocessor. An admin setting controls this, and the default has varied by tenant and region. **Agents and connectors:** each one is another path for data.

Worth saying out loud
Never assume "enterprise Copilot" means every control you want is switched on. Web search and other model providers are tenant settings, and someone has to look at them.

© 2026 Growth Partner Pros. All Rights Reserved.

QUESTION 4 OF 6

Access: what can Copilot reach?

Least privilege still applies: Copilot should only reach what the job needs. In Microsoft 365, that comes down to permissions, because Copilot works as the person using it and sees what they can see.

The real risk is oversharing

Old SharePoint sites, "anyone in the organization" links and large Teams memberships give people access they never use. Before Copilot, nobody stumbled on those files. With Copilot, a plain question can bring them up.

Microsoft's tools for finding and fixing it

Tool	What it does
Data access governance reports	Show sites that are shared broadly or have sharing links, so you know where to look first.
Restricted Content Discovery	Keeps a site out of Copilot and organization-wide search results without changing anyone's permissions. A good stopgap while you clean up.
Restricted access control	Limits a site to the members of a named group.
Sensitivity labels on sites	Set privacy and sharing rules for a whole site or team.

These SharePoint Advanced Management features become available once at least one Microsoft 365 Copilot license is assigned. A few features still need a separate add-on.

Same tool, two risk profiles

Agent A: answers from one folder

An Agent Builder agent that answers HR policy questions from one approved SharePoint folder. If it's wrong, a person reads a bad answer.

Agent B: reaches and acts everywhere

An agent that can read all mailboxes and sites, send email and update calendars. If it's wrong, it can send, forward or book the mistake.

Access is what it can reach. Action is what it can change.

Set access before files move into SharePoint, not after Copilot finds them.

© 2026 Growth Partner Pros. All Rights Reserved.

QUESTION 5 OF 6

Action: what can Copilot change?

The big line is between Copilot that recommends and Copilot that acts. In Microsoft 365, which Copilot you use largely decides which side of that line you're on.

Recommends	Acts
"Draft a reply to this candidate" in Outlook	An agent that replies to candidates on its own
"Summarize this 360 file" in Copilot Chat	An agent that emails summaries to managers automatically
"Which times work for all four interviewers?"	An agent that books, moves and cancels interviews

The autonomy ladder, with Microsoft examples

Level	What it means	Where you'll see it in Microsoft 365
0 Answers	Responds to questions	Copilot Chat. An Agent Builder agent answering from approved files.
1 Recommends	A person decides and acts	Copilot suggesting meeting times, flagging themes in comments
2 Drafts	A person reviews, then sends or files it	Copilot in Word, Outlook and Excel. You press Send.
3 Acts after approval	A person approves every action	Copilot Studio agents with actions set to ask before they run
4 Acts within limits	Acts alone inside written limits, and logs everything	Copilot Studio agents with triggers and connectors
5 Plans its own steps	Decides its next steps across systems	Copilot Cowork, which breaks a goal into tasks across Outlook, Teams and Office, and can be allowed to use a browser

Good starting point

Copilot Chat and Agent Builder keep you at levels 0 to 2. They're included with Microsoft 365 Copilot and don't need an IT project.

Needs IT and governance first

Copilot Studio actions and Cowork reach levels 3 to 5. Cowork must be turned on by an admin, uses usage-based billing, and keeps browser use off unless an admin allows it.

Organizations earn their way up the ladder

Move up one level only after a trial period, tracked errors and the owner's sign-off. Nobody should start at the top.

© 2026 Growth Partner Pros. All Rights Reserved.

QUESTION 6 OF 6

Oversight: where must a human decide?

Tie human approval to consequence and how hard the action is to reverse. Then make sure there's a record.

GREEN Copilot can do it

Formatting a document. Summarizing a public article. Turning meeting notes into a task list.

YELLOW Copilot drafts, a person approves

Job descriptions. Candidate emails. 360 summaries before they reach a manager.

RED A person owns the decision

Hiring, pay, promotion, discipline and termination. Legal conclusions. Anything a regulator could ask about.

The Microsoft paper trail

What	Why it matters
Purview audit log	Records that Copilot interactions happened, with the user, time and app. How long logs are kept depends on your license.
Retention policies	Keep Copilot prompts and responses for as long as your records rules require. Set them before rollout, because they don't reach back.
eDiscovery	Lets legal and compliance find and export Copilot prompts and responses for an investigation.

For regulated firms, ask compliance which of these your recordkeeping rules require before anyone uses Copilot with client or employee information.

The output check

Controls on what goes in don't cover what comes out. Before anything Copilot produced is used:

Is it true?

Numbers, names and facts checked against the source file. Excel does the math, not the chat.

What's in it?

No sensitive detail carried in by accident. Check the label Copilot shows.

Where does it go?

Who will see it, and is the sharing link set to the right people?

© 2026 Growth Partner Pros. All Rights Reserved.

PUTTING IT TOGETHER

The decision grid, for Copilot

Find the data class down the side and the autonomy level across the top. The cell says what's required. It's a starting point each organization calibrates to its own risk tolerance.

Data class	Answer or recommend (levels 0 to 1)	Draft (level 2)	Act with approval (level 3)	Act on its own (levels 4 to 5)
Public	GREEN Copilot Chat with a work account	GREEN Spot-check before use	YELLOW Approve each action	YELLOW Written limits, audit logging, owner reviews
Internal	GREEN Work account, enterprise data protection on	GREEN Author reviews before use	YELLOW Approve each action, logged in Purview	YELLOW Written limits, logging, agent can be blocked fast
Confidential	YELLOW Licensed Copilot, files labeled, permissions checked	YELLOW A person reviews before anything leaves	YELLOW Approve each action, logged, owner named	RED Owner approves the use case, pilot first
Restricted	RED Redact or use synthetic data first	RED Encrypted label, restricted site, owner sign-off	RED Owner, security and legal sign-off	RED Most organizations stop here

One override

If a use case fails the red-flag test on the next page, it's red by default, wherever it lands on the grid.

© 2026 Growth Partner Pros. All Rights Reserved.

A QUICK TEST FOR ANY USE CASE

The red-flag test, in Microsoft 365

Simon Willison calls it the lethal trifecta: an AI that has all three of these at once. Here's what each one looks like in Copilot.

The flag	In Microsoft 365, it looks like
1 Access to private data	Licensed Copilot reading mailboxes, chats, OneDrive and SharePoint
2 Exposure to untrusted content	Emails from outside, résumés, vendor PDFs, web search results, documents shared in from other companies
3 A way to send information out	Sending email, posting in Teams, creating sharing links, Copilot Studio connectors, Cowork with browser use on

> **The rule**
> If a use case has all three, it's red by default until a control removes one. Keeping Copilot at Draft, where a person presses Send, takes away the third.

When the model gets fooled

Emails, résumés and PDFs can carry hidden instructions that Copilot reads as commands. Microsoft builds in its own defenses, and the framework doesn't rely on them alone. Each layer limits the damage on its own:

Layer	The Microsoft 365 control
Owner	Sees it in the audit log and blocks the agent from the admin center
Data	Encrypted labels keep restricted text out of answers
Environment	Work accounts, web search policy, AI provider settings
Access	Tight permissions and Restricted Content Discovery
Action	Drafting tools first, approvals on any action that sends or changes something
Oversight	A person approves the consequential step, and Purview keeps the record

© 2026 Growth Partner Pros. All Rights Reserved.

WORKED EXAMPLE

"We want Copilot to summarize our 360 feedback"

The answer doesn't start with prompts. It starts with the six questions.

Question	The answer
Owner	The VP of Human Resources, with a review date after the first cycle
Data	One person's ratings and comments from the Forms export. Confidential. Summaries get the Confidential label.
Environment	Licensed Microsoft 365 Copilot with a work account. Web search off for this task. Compliance has reviewed the AI provider settings.
Access	Exports and summaries live in a private HR site, set up before any files move. Managers see only their own people's summaries.
Action	Level 2. Copilot drafts the summary and Excel does the math. A person reviews it, saves it and shares it. Later, an Agent Builder agent can run the same steps, still at level 2.
Oversight	HR reads every summary before a manager sees it. Ratings, pay and promotion decisions stay with people. Groups smaller than three are left out to protect anonymity.

Red-flag test

Yes private data
Partly untrusted content (free-text comments)
No way to send at level 2

YELLOW **Grid result**

Confidential at Draft. A person reviews before anything leaves HR. Moving to automatic emails to managers would add the third flag, so every send would need approval.

Only after those decisions

do we write the prompts and build the agent.

© 2026 Growth Partner Pros. All Rights Reserved.

BEFORE YOU ROLL OUT

Ten Copilot settings to look at first

Take this list to whoever runs your Microsoft 365 tenant. Most are a short conversation, not a project.

	Setting or decision	Question to ask
1	**Who has the admin roles**	Who is our AI Administrator and Global Administrator?
2	**Copilot licenses**	Who has a Microsoft 365 Copilot license, and who only has Copilot Chat?
3	**Web search**	Is web search on in Copilot, and for whom?
4	**AI providers operating as Microsoft subprocessors**	Are Anthropic models on in our tenant? Has compliance reviewed that?
5	**Cowork and usage-based billing**	Is Cowork on? If so, for whom, with what spending limits, and is browser use off?
6	**Agents**	Who can build and share agents? Who reviews the agent inventory?
7	**Oversharing reports**	Have we run the data access governance reports in SharePoint?
8	**Restricted Content Discovery**	Which sensitive sites should be kept out of Copilot until permissions are cleaned up?
9	**Sensitivity labels**	Are labels published? Which ones encrypt, and do they block Copilot where they should?
10	**Audit and retention**	Is Copilot activity being logged? Is there a retention policy for Copilot prompts and responses?

> **A note on menu names**
> Microsoft renames and moves Copilot settings often. Confirm current names and paths on Microsoft Learn or in your admin center before you rely on this list.

© 2026 Growth Partner Pros. All Rights Reserved.

FURTHER READING

Sources

Checked November 2026. Microsoft documentation changes often, so treat it as current only as of that date.

Microsoft

Enterprise data protection in Microsoft 365 Copilot and Copilot Chat
learn.microsoft.com/en-us/copilot/microsoft-365/enterprise-data-protection

Microsoft 365 Copilot best practices with SharePoint
learn.microsoft.com/en-us/sharepoint/sharepoint-copilot-best-practices

SharePoint Advanced Management features with a Copilot license
learn.microsoft.com/en-us/sharepoint/sharepoint-advanced-management-features-copilot-license

Copilot architecture, data protection and auditing
learn.microsoft.com/en-us/copilot/microsoft-365/microsoft-365-copilot-architecture-data-protection-auditing

Microsoft Purview protections for Copilot
learn.microsoft.com/en-us/purview/ai-microsoft-purview

Manage public web access in Copilot
learn.microsoft.com/en-us/copilot/microsoft-365/manage-public-web-access

Copilot in Microsoft 365 apps with Anthropic models
learn.microsoft.com/en-us/microsoft-365/copilot/copilot-anthropic-apps

Copilot Cowork admin and governance
learn.microsoft.com/en-us/microsoft-365/copilot/cowork/cowork-admin-governance

Governance and lifecycle actions for agents in the Microsoft 365 admin center
learn.microsoft.com/en-us/microsoft-365/admin/manage/agent-actions

Cost considerations for Copilot agents
learn.microsoft.com/en-us/microsoft-365/copilot/extensibility/cost-considerations

From the original framework

OWASP Top 10 for LLM Applications 2025
genai.owasp.org/llm-top-10

NIST AI 600-1, Generative AI Profile
nist.gov/itl/ai-risk-management-framework

"The lethal trifecta for AI agents," Simon Willison, June 16, 2025
simonwillison.net/2025/Jun/16/the-lethal-trifecta



Caroline Hinton, Growth Partner Pros
caroline.hinton@growthpartnerpros.com

© 2026 Growth Partner Pros. All Rights Reserved.